



RELAZIONE DI LABORATORIO DI CYBERSECURITY

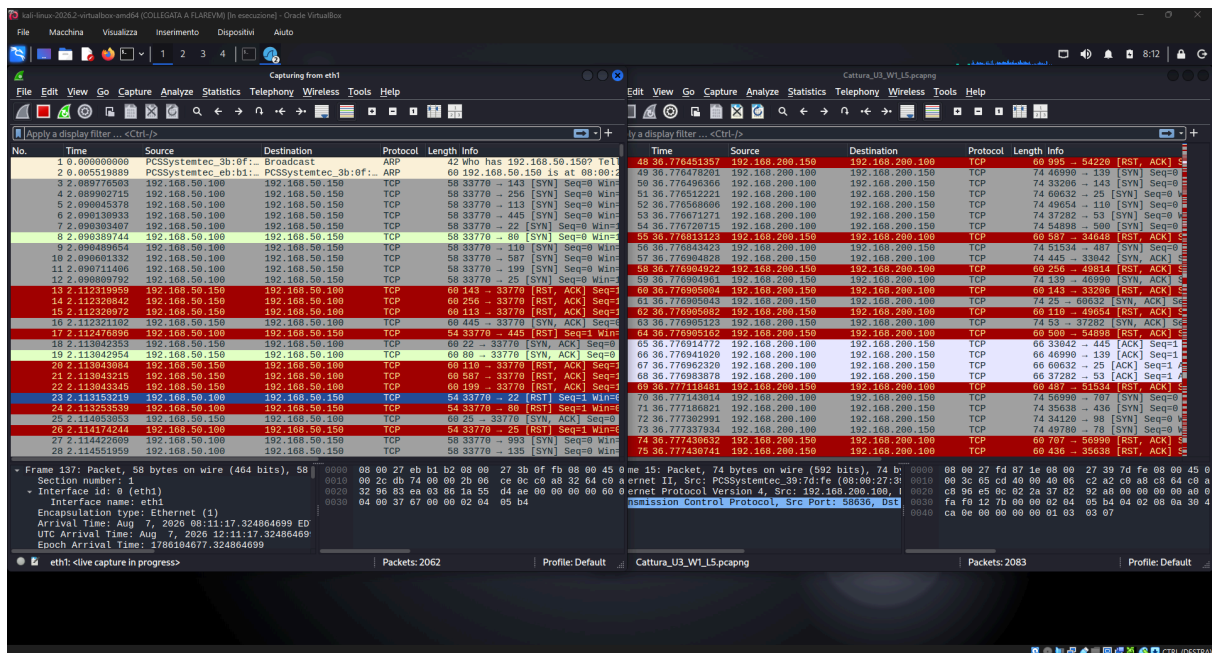
Relazione Tecnica di Sicurezza Informatica: Analisi di Indicatori di Compromissione (IOC) su Cattura di Rete



Dati dello Studente

Campo	Dettaglio
Nome e Cognome	Lorenzo Rizzuti
Matricola	
Corso di Studi	Epicode
Anno Accademico	2025/2026
Docente	Paolo Rampino 🙌💖

Data: 07 agosto 2026



1. Introduzione e Scopo dell'Esercitazione

L'esercitazione odierna aveva l'obiettivo di applicare le conoscenze teoriche sulla Threat Intelligence, focalizzandosi sull'identificazione pratica di Indicatori di Compromissione (IOC) all'interno di una cattura di rete.

Per raggiungere questo scopo, il docente ci ha fornito un file di traccia di rete (.pcapng) da analizzare con Wireshark. Come attività preliminare per comprendere meglio il comportamento degli attaccanti nella fase di ricognizione, ho eseguito personalmente una scansione attiva tramite lo strumento Nmap su un indirizzo IP della mia rete locale (192.168.50.150), utilizzando una scansione SYN (-sS). In questo modo, ho potuto confrontare il traffico generato dal mio tool con quello presente nella cattura del professore.

Di seguito riporto l'analisi dettagliata degli IOC riscontrati, le ipotesi sui vettori d'attacco e le contromisure da me suggerite.

2. Analisi degli Indicatori di Compromissione (IOC) Identificati

Dopo aver caricato il file `Cattura_U3_W1_1.5.pcapng` in Wireshark, ho filtrato e analizzato i singoli pacchetti. Ho individuato i seguenti IOC, che suggeriscono la presenza di un attacco in fase di ricognizione:

- **Attività di Scansione delle Porte (Port Scanning):**
Ho osservato un flusso anomalo di pacchetti TCP con il flag SYN (Synchronize) inviati in rapida successione. Nello specifico, la macchina con IP 192.168.50.156 (che ho identificato come potenziale attaccante) ha effettuato centinaia di tentativi di connessione verso il target 192.168.50.150 su un'ampia gamma di porte (es. 445, 135, 80, 5770, 3770, ecc.).
 - **Firma di Scansione Stealth (TCP SYN Scan):**
Analizzando il seguito della conversazione, ho notato che il target rispondeva correttamente ai pacchetti SYN con pacchetti SYN-ACK (indicando che le porte erano aperte). Tuttavia, l'host 156 non completava mai il "Three-way handshake" (non inviava l'ACK finale), ma rispondeva invece chiudendo immediatamente la connessione con pacchetti RST (Reset). Questa è la firma classica di una scansione "stealth" di Nmap (-sS), che ho replicato anche io nella mia prova a sinistra, confermando che si tratta di un'attività di enumerazione automatizzata.
 - **Enumerazione di Servizi Critici:**
La scansione non era casuale. L'attaccante ha puntato in modo specifico su porte note per essere vettori di attacco, in particolare:
 - Porta 445 (SMB): Classico vettore per attacchi ransomware o di lateral movement (es. EternalBlue).
 - Porta 135 (RPC): Spesso bersaglio per l'esecuzione di codice in remoto su sistemi Windows.
 - Porta 80: Per rilevare eventuali servizi web esposti.
-

3. Ipotesi sui Potenziali Vettori di Attacco

Sulla base degli IOC identificati, ho elaborato le seguenti ipotesi sul modus operandi dell'aggressore:

1. Fase Iniziale della Cyber Kill Chain: L'attacco è ancora in una fase embrionale. Non ho osservato trasferimenti di payload, comandi malevoli o esfiltrazione di dati. L'attaccante sta eseguendo una ricognizione attiva per mappare la superficie d'attacco della rete, capendo quali servizi sono in ascolto sulla macchina vittima.
 2. Intenzione di Movimento Laterale o Sfruttamento di SMB: La scansione massiccia delle porte 135 e 445 indica fortemente che l'obiettivo dell'attaccante è sfruttare vulnerabilità note del protocollo SMB di Windows. Se la macchina target fosse risultata vulnerabile e non patchata, la fase successiva sarebbe stata probabilmente l'iniezione di un payload per ottenere l'accesso remoto (RCE) o la cifratura dei dati tramite ransomware.
-

4. Azioni Raccomandate per la Mitigazione e la Prevenzione

Sebbene l'analisi mostri un attacco in fase di scansione, l'operatività aziendale è comunque a rischio. Ho formulato le seguenti strategie di difesa, suddividendole in azioni immediate e future:

Azioni di Risposta Immediata (Contenimento):

- Isolamento degli Host: Ho raccomandato di disconnettere fisicamente o logicamente dalla rete sia l'host attaccante (192.168.50.156) che l'host vittima (192.168.50.150). Questo impedirebbe che la scansione si evolva in un vero e proprio exploit. In particolare, l'host 156 va messo in quarantena per verificare se si tratta di un dispositivo già compromesso da un malware.

- **Verifica dei Log di Sicurezza:** Consiglio di consultare immediatamente i log di sistema e di sicurezza dell'host 192.168.50.150, concentrandosi su eventuali tentativi di autenticazione anomali o crash di servizi sulle porte 445 e 135.

Azioni di Prevenzione (Sicurezza a Lungo Termine):

- **Implementazione di un IDS/IPS:** Ho suggerito di configurare sistemi come Snort o Suricata con regole specifiche per bloccare il "Port Scanning". L'IDS dovrebbe essere in grado di rilevare pattern come "X tentativi di SYN verso porte diverse in Y secondi" e attivare un blocco automatico dell'IP sorgente.
 - **Hardening del Firewall di Rete:** È fondamentale bloccare a livello di firewall il traffico in ingresso diretto verso le porte 135 (RPC) e 445 (SMB) per tutti gli host che non necessitano di condivisione file. L'esposizione di queste porte sulla rete locale è un grave rischio.
 - **Patch Management:** Consiglio di implementare una politica rigorosa di aggiornamento dei sistemi Windows, assicurandosi che la patch di sicurezza per la vulnerabilità MS17-010 (EternalBlue) e successive sia installata su tutti i server e le workstation.
 - **Segmentazione di Rete (VLAN):** Per evitare che un host nella rete client possa scansionare direttamente i server di produzione, propongo di implementare una segmentazione in VLAN, isolando il traffico critico in sottoreti dedicate.
-

5. Conclusioni

L'esercitazione mi ha permesso di comprendere l'importanza dell'analisi dei singoli pacchetti per identificare le prime fasi di una minaccia informatica. La scansione nmap -sS, che ho eseguito e visto replicata nella cattura del professore, si è rivelata un IOC estremamente evidente, segnale di un'intenzione ostile di mappare l'infrastruttura. La difesa da questo tipo di minaccia richiede un approccio a più livelli che combini la

visibilità offerta da Wireshark, la rilevazione automatica (IDS) e una politica di sicurezza di rete restrittiva.

P.S: Comando usando nmap -sT -p 1-1000 192.168.50.150 "Metasploitable2"